

Техника атаки AS-REP Roasting: Механика, актуальность и защита

 redsec.by/article/tehnika-ataki-as-rep-roasting-mehanika-aktualnost-i-zashita

Red Teams | 28 апреля 2026



В корпоративной архитектуре Active Directory (AD) механизмы аутентификации Kerberos являются основополагающим элементом безопасности. Однако технический долг, устаревшие конфигурации и стремление к обеспечению обратной совместимости часто открывают двери для критических векторов атак. Одной из таких техник является **AS-REP Roasting**. В данном техническом руководстве мы подробно разберем механику эксплуатации уязвимых учетных записей, рассмотрим актуальный инструментарий Red Team и сформируем комплексную стратегию защиты и мониторинга для Blue Team.

1. Что такое AS-REP Roasting?

AS-REP Roasting — это техника извлечения хешей паролей учетных записей Active Directory (AD), у которых в свойствах принудительно отключена обязательная предварительная аутентификация Kerberos. Технически это выражается в наличии установленного флага в атрибуте `userAccountControl` — а именно атрибута `UF_DONT_REQUIRE_PREAUTH` (шестнадцатеричное значение `0x400000`, десятичное `4194304`).

В отличие от родственной атаки *Kerberoasting*, где целью выступают исключительно сервисные учетные записи с установленным Service Principal Name (SPN), AS-REP Roasting направлен на **абсолютно любого пользователя** домена, конфигурация которого была ослаблена. Атака позволяет злоумышленнику, даже не имея предварительного доступа к валидным учетным данным (без знания пароля), запросить специфические криптографические данные у контроллера домена (DC) и провести офлайн-брутфорс (взлом методом перебора словарей или масок) для получения пароля пользователя в открытом виде.

Важно: Архитектурное отличие

Для эксплуатации Kerberoasting атакующему требуется валидная доменная учетная запись, чтобы запросить TGS (Ticket-Granting Service). Для AS-REP Roasting в ряде сценариев достаточно лишь сетевого доступа к контроллеру домена (порт 88 TCP/UDP) и знания логина (имени пользователя) жертвы, так как атака происходит на этапе запроса TGT (Ticket-Granting Ticket).

2. Механика атаки: Анатомия протокола Kerberos

Чтобы досконально понять природу этой уязвимости, необходимо на молекулярном уровне рассмотреть стандартный процесс аутентификации Kerberos и то, как его логика деградирует при ошибке конфигурации.

Стандартный процесс (с Pre-Authentication)

По умолчанию в Active Directory для всех новых пользователей включена функция Kerberos Pre-Authentication. Это механизм защиты от перебора паролей на стороне сервера (KDC — Key Distribution Center).

- **Шаг 1. AS-REQ (Authentication Service Request):** Пользователь отправляет первичный запрос к KDC на контроллере домена. В структуру этого запроса встраивается поле PA-DATA (Pre-Authentication Data), содержащее временную метку (timestamp), зашифрованную симметричным ключом (хешем пароля пользователя).
- **Шаг 2. Валидация KDC:** KDC извлекает хеш пароля запрашивающего пользователя из базы NTDS.dit, расшифровывает временную метку и проверяет её. Если время совпадает (с учетом допустимой погрешности, по умолчанию 5 минут), KDC удостоверяется, что отправитель действительно знает пароль.
- **Шаг 3. AS-REP (Authentication Service Response):** Успешно проверив подлинность, KDC отправляет в ответ TGT-билет (зашифрованный хешем сервиса krbtgt) и сессионный ключ. Часть этого ответа (сессионный ключ и метаданные сессии) зашифрована **хешем пароля пользователя**.

Уязвимый процесс (без Pre-Authentication)

Сценарий радикально меняется, если для учетной записи в оснастке AD UC установлена галочка *"Do not require Kerberos preauthentication"* (Не требовать предварительную проверку подлинности Kerberos).

1. **Запрос атакующего:** Злоумышленник формирует и отправляет пустой запрос AS-REQ от имени целевого уязвимого пользователя. Поскольку Pre-Authentication отключена, атакующему **не нужно** отправлять зашифрованную временную метку (соответственно, пароль для инициирования запроса не требуется).
2. **Отсутствие валидации:** KDC принимает запрос, видит флаг UF_DONT_REQUIRE_PREAUTH и не требует доказывать знание пароля на этапе запроса. Сервер сразу формирует ответ.
3. **Выдача AS-REP:** KDC возвращает сообщение AS-REP. Как и в стандартном процессе, часть этого ответа (зашифрованный сессионный ключ в блоке enc-part) зашифрована хешем пароля целевого пользователя.
4. **Офлайн-взлом:** Атакующий перехватывает этот AS-REP, извлекает зашифрованный блок и загружает его в специализированные утилиты (например, Hashcat), чтобы с помощью вычислительных мощностей GPU восстановить исходный пароль.

Практика: Понимание структуры ответа

В дампе сетевого трафика атакующий ищет структуру типа enc-part внутри AS-REP. Если используется шифрование RC4 (Тип 23 / 0x17), зашифрованный блок легко извлекается и форматируется в строку вида `$krb5asrep$23$user@domain.com:cipher_text` для передачи в крекер.

3. Ландшафт угроз и актуальность на 2026 год

Хотя концепция AS-REP Roasting не является новой, в 2026 году она остается критически опасным вектором в арсенале АPT-группировок и коммерческих пентестеров. Причины устойчивости этой угрозы многогранны:

- **Легаси и технический долг:** Предварительную аутентификацию исторически часто отключали для поддержки старых Linux-приложений, устаревших сетевых сканеров, принтеров или проприетарного софта, которые не умели корректно обрабатывать PA-DATA в протоколе Kerberos. Зачастую это делалось как "временное решение", которое осело в инфраструктуре навсегда из-за страха нарушить бизнес-процессы.

- **Исключительная скрытность (Stealth):** Атака выполняется от лица неаутентифицированного источника (или скомпрометированного хоста), не требует привилегий доменного администратора и практически не генерирует шума. Оффлайн-брутфорс происходит на фермах видеокарт атакующего вне сети жертвы, что **никогда не вызывает блокировку учетных записей** в AD (Account Lockout Policy на офлайн-атаки не распространяется).
- **Активность шифровальщиков (Ransomware):** Согласно отчетам об инцидентах ИБ (включая детальные разборы активностей таких синдикатов как Yurei в 2025–2026 гг., а также BlackSuit), AS-REP Roasting автоматизирован и включен в стандартный плейбук (playbook) этапа разведки и повышения привилегий сразу после первоначального проникновения в сеть (Initial Access).

Риски: Переход на AES и атаки даунгрейда (Downgrade Attacks)

В современных доменных сетях (развернутых на базе Windows Server 2022 и 2025) по умолчанию форсируется криптография AES-256 (тип шифрования 18 / 0x12) вместо скомпрометированного алгоритма RC4-HMAC. Хотя AES-256 значительно медленнее поддается брутфорсу, атака AS-REP Roasting всё ещё возможна, если пользователи применяют слабые или словарные пароли. Более того, продвинутые атакующие используют техники **даунгрейда шифрования** (например, модифицируя параметры запроса через утилиты Rubeus или ASRepCatcher). Злоумышленник манипулирует списком поддерживаемых типов шифрования в AS-REQ, пытаясь заставить KDC выдать AS-REP с использованием уязвимого алгоритма RC4.

4. Инструментарий атакующих (Red Team Operations)

Современные злоумышленники и инженеры Red Team используют стандартизированный, высокоэффективный набор утилит для автоматизации процесса поиска и эксплуатации.

4.1. NetExec (nxc)

NetExec стал индустриальным стандартом швейцарского ножа для пентестеров после официального прекращения поддержки и развития CrackMapExec. Утилита позволяет выполнить автоматический неаутентифицированный (или аутентифицированный) LDAP-запрос к DC для поиска уязвимых пользователей и немедленно собрать их хеши в формате, готовом для Hashcat.

Команда запуска:

```
# Аутентифицированный поиск всех уязвимых пользователей и извлечение AS-REP
nxc ldap 192.168.10.10 -u 'john.doe' -p 'P@ssw0rd123!' --asreproast output_hashes.txt

# Неаутентифицированный запрос (работает, если разрешен анонимный бинд к LDAP)
nxc ldap 192.168.10.10 -u '' -p '' --asreproast output_hashes.txt
```

4.2. Impacket (GetNPUsers.py)

Классический Python-скрипт из набора Impacket. Он напрямую взаимодействует с протоколами LDAP и Kerberos. Если у атакующего есть хотя бы одна валидная низкопривилегированная доменная учетная запись, скрипт автоматически выгрузит все доступные хеши пользователей с атрибутом UF_DONT_REQUIRE_PREAUTH.

Команда запуска:

```
# Запрос хешей для всего домена (требуется валидный пользователь для LDAP-запроса)
python3 GetNPUsers.py corp.local/john.doe:P@ssw0rd123! -request -format hashcat -out

# Целенаправленная атака на конкретного пользователя (пароль не нужен)
python3 GetNPUsers.py corp.local/vulnerable_user -no-pass -request -format hashcat
```

4.3. Rubeus

Rubeus — это мощный C#-инструмент (разработанный проектом GhostPack) для работы с Kerberos из оперативной памяти (in-memory). Он является основным выбором при работе через C2-фреймворки (например, Cobalt Strike, Mythic) на скомпрометированной Windows-машине, так как позволяет обходить многие статические сигнатуры антивирусов (AV) и систем класса EDR.

Команда запуска (из сессии маяка / beacon):

```
# Выполнение AS-REP Roasting для всех уязвимых учеток с выводом в формате Hashcat
execute-assembly /path/to/Rubeus.exe asreproast /format:hashcat /nowrap
```

Ошибка эксплуатации: Слепое доверие к RC4

Начинающие пентестеры часто предполагают, что KDC всегда вернет хеш в формате RC4. В сетях 2026 года (Windows Server 2025) Rubeus по умолчанию может получить ответ в формате AES-256. В этом случае хеш будет начинаться с \$krb5asrep\$18\$. Если оператор не обновит синтаксис команды Hashcat, перебор закончится ошибкой парсинга хеша.

4.4. Офлайн-брутфорс: Hashcat и John the Ripper

Полученные строки — это не пароли, а зашифрованный материал. Их необходимо взломать на мощных GPU-станциях. Hashcat поддерживает различные режимы для разных типов шифрования Kerberos.

Запуск Hashcat:

```
# Взлом хешей RC4 (etype 23) с использованием режима 18200
hashcat -m 18200 -a 0 asrep_rc4.txt rockyou.txt --rules-file OneRuleToRuleThemAll.ru
```

```
# Взлом хешей AES-256 (etype 18) с использованием режима 19700
hashcat -m 19700 -a 0 asrep_aes.txt rockyou.txt
```

5. Обнаружение (Detection) и мониторинг (Blue Team)

Выявление попыток эксплуатации AS-REP Roasting требует комплексного подхода, сочетающего анализ логов конечных точек (контроллеров домена) в системах SIEM/EDR и глубокий анализ сетевого трафика (DPI/NDR). Атака отличается низким уровнем шума, однако оставляет четкие криптографические и поведенческие артефакты.

5.1. Анализ журналов событий Windows (SIEM/EDR)

Основным источником данных для обнаружения на уровне хоста является аудит событий Kerberos на контроллерах домена (DC). Инженерам SOC (Security Operations Center) необходимо настроить сбор и корреляцию событий запроса билетов TGT.

Ключевой идентификатор (Event ID): 4768 — A Kerberos authentication ticket (TGT) was requested.

Для создания высокоточного правила обнаружения (алерта) необходимо опираться на комбинацию следующих полей внутри события 4768:

- **Pre-Authentication Type (Тип предварительной проверки подлинности):** Равен 0 (или отображается как - / пустое значение). Это прямо указывает на то, что билет был запрошен без предоставления зашифрованной временной метки.
- **Service Name (Имя службы):** krbtgt (запрос направлен к службе выдачи билетов).
- **Ticket Options:** Часто имеет значение 0x40810010 (стандартные опции Rubeus/Impacket).

Практика: Sigma-правило для SIEM

Ниже представлен пример базового Sigma-правила для выявления аномальных запросов TGT без Pre-Authentication, которое можно конвертировать для Elastic Security, Splunk или QRadar:

```
title: Обнаружение AS-REP Roasting (Отсутствие Pre-Auth)
id: 5a56312a-36b0-4c3e-9669-0268ecbcab96
status: experimental
description: Детектирование запроса TGT без предварительной аутентификации, что явля
logsource:
  product: windows
  service: security
detection:
  selection:
```

```
EventID: 4768
ServiceName: 'krbtgt'
PreAuthType:
  - '0'
  - '-'
filter_machine_accounts:
  TargetUserName|endswith: '$' # Исключаем легитимные запросы от машинных уче
condition: selection and not filter_machine_accounts
falsepositives:
  - Легитимные старые приложения или Linux-интеграции, жестко требующие отключения
level: high
```

Аномалии шифрования (Downgrade-атаки)

Особое внимание аналитикам следует уделять событиям 4768, где поле **Ticket Encryption Type** (Тип шифрования билета) равно 0x17 (что соответствует устаревшему алгоритму RC4-HMAC). В корпоративных сетях, которые официально перешли на криптографию AES-256 (коды 0x12 для AES-128 или 0x13 для AES-256), внезапное появление запросов RC4 к службе krbtgt является критическим индикатором (IoC) компрометации (попытка даунгрейда атакующим).

5.2. Анализ сетевого трафика (NDR / PCAP)

Сетевые сенсоры способны выявить атаку до того, как она отразится в журналах DC. Эффективный NDR (Network Detection and Response) должен обнаруживать характерную «связку» действий (цепочку активности):

1. **Разведка (LDAP Enumeration):** Атакующий (или его инструмент) отправляет LDAP-запрос к контроллеру домена для поиска уязвимых учетных записей. В сетевом пакете будет виден специфический битовый фильтр OID (Object Identifier): `userAccountControl:1.2.840.113556.1.4.803:=4194304`.
Примечание: 4194304 — это десятичное представление флага UF_DONT_REQUIRE_PREAUTH (0x400000), а OID 1.2.840... обозначает правило битового сравнения (LDAP_MATCHING_RULE_BIT_AND).
2. **Эксплуатация (Kerberos AS-REQ):** Сразу после LDAP-ответа по сети проходит один или несколько пакетов протокола Kerberos v5 (порт 88). Если проанализировать AS-REQ в Wireshark, в нем будет **отсутствовать** структура `padata` типа `PA-ENC-TIMESTAMP` (Type 2).

6. Меры предотвращения и защиты (Mitigation)

Эффективная защита от AS-REP Roasting сводится к строгой гигиене Active Directory и устранению архитектурного технического долга. Проактивные меры значительно надежнее реагирования на уже случившийся инцидент.

6.1. Включение Pre-Authentication (Аудит и исправление)

Необходимо на регулярной основе (через скрипты автоматизации или CI/CD инфраструктуры) аудировать AD на наличие пользователей с отключенной предварительной проверкой подлинности и принудительно включать её.

Рекомендация: Поиск уязвимых учеток через PowerShell

Используйте стандартный модуль ActiveDirectory для выявления всех учетных записей (исключая заблокированные), подверженных атаке:

```
# Импорт модуля и поиск всех активных пользователей без Pre-Auth
Import-Module ActiveDirectory
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true -and Enabled -eq $true} -Propert
```

Для устранения уязвимости можно массово изменить атрибут с помощью следующего пайплайна (применять с осторожностью, предварительно проверив, не сломает ли это легаси-сервисы):

```
Get-ADUser -Filter {DoesNotRequirePreAuth -eq $true} | Set-ADUser -DoesNotRequirePre
```

В крупных инфраструктурах рекомендуется использовать инструменты глубокого анализа графов, такие как **BloodHound** (для поиска путей компрометации) или утилиту **Purple Knight**, которая автоматически генерирует отчеты о нарушениях безопасности конфигурации AD, включая AS-REP уязвимости.

6.2. Политики паролей (Password Policies)

Поскольку финальная стадия атаки AS-REP Roasting опирается на офлайн-взлом (перебор хешей на GPU), надежная и математически стойкая парольная политика делает её нерентабельной (вычислительно невозможной в адекватные сроки).

Требуйте пароли длиной **не менее 15 символов**. Для сервисных учетных записей, которым по историческим причинам всё же требуется отключенная Pre-Auth, длина пароля должна составлять 30+ символов (или использоваться MSA/gMSA, управляемые самим AD).

6.3. Отказ от RC4 и форсирование AES

Внедрение политик безопасности, полностью отключающих использование устаревшего алгоритма RC4 в домене, кардинально усложнит жизнь атакующим. Взлом хеша AES-256 (тип 18) требует несоизмеримо больших вычислительных мощностей по сравнению с RC4.

Конфигурация через Group Policy Object (GPO):

Перейдите в Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Local Policies -> Security Options.

Найдите политику **Network security: Configure encryption types allowed for Kerberos** и оставьте включенными *только* параметры: AES128_HMAC_SHA1, AES256_HMAC_SHA1 и Future encryption types. Убедитесь, что галка с RC4_HMAC_MD5 снята.

6.4. Защита от даунгрейда (msDS-SupportedEncryptionTypes)

Для пресечения атак даунгрейда (когда злоумышленник через Rubeus запрашивает RC4 тикет в AES-сети) необходим строгий контроль за атрибутом msDS-SupportedEncryptionTypes для всех объектов домена (пользователей и компьютеров). Если этот атрибут не задан (значение `0` или `NULL`), KDC может согласиться на выдачу билета в RC4 для обеспечения совместимости. Установка значения 24 (AES 128 + AES 256) принудительно заставит контроллер домена общаться с этой учетной записью только по современным стандартам шифрования.

Вывод

AS-REP Roasting — это яркий пример того, как технический долг и ослабление стандартных механизмов безопасности ради совместимости могут создать критические векторы проникновения в корпоративную сеть. Атака опасна своей невидимостью: она не генерирует блокировок учетных записей (Account Lockouts) и проводится без начальных привилегий (в неаутентифицированном варианте). В реалиях 2026 года защита от данной угрозы базируется не столько на приобретении новых ИБ-решений, сколько на строгой базовой гигиене Active Directory: отключении алгоритма RC4, регулярном аудите атрибута UF_DONT_REQUIRE_PREAUTH и внедрении криптографически стойких паролей длиннее 15 символов.

Часто задаваемые вопросы (FAQ)

1. Чем принципиально AS-REP Roasting отличается от Kerberoasting?

AS-REP Roasting атакует любых пользователей с отключенной предварительной проверкой подлинности на этапе получения TGT (запрос AS-REQ). Для этого злоумышленнику даже не нужен пароль в домене. Kerberoasting нацелен на сервисные учетные записи (с SPN) на этапе получения TGS-билета, и для её проведения атакующий уже должен обладать валидной доменной учетной записью.

2. Может ли AS-REP Roasting заблокировать учетную запись жертвы (Account Lockout)?

Нет. Взаимодействие с контроллером домена ограничивается запросом и получением зашифрованных данных. Весь процесс перебора пароля (брутфорс) происходит офлайн на оборудовании атакующего. Контроллер домена не фиксирует факты неверного ввода пароля.

3. Можно ли выполнить эту атаку вообще без учетной записи в домене?

Да, если злоумышленник знает логин уязвимого пользователя и имеет сетевой доступ к порту 88 (Kerberos) контроллера домена. Сложность заключается лишь в поиске таких пользователей: если анонимный доступ к LDAP (Anonymous Bind) запрещен, злоумышленнику придется угадывать имена (например, с помощью генерации списков логинов на основе OSINT).

4. Почему мы всё ещё видим RC4 в ответах Kerberos, если наш домен работает на Windows Server 2022/2025?

По умолчанию контроллер домена пытается согласовать наилучший тип шифрования, поддерживаемый обеими сторонами. Если атрибут msDS-SupportedEncryptionTypes учетной записи не сконфигурирован жестко на использование только AES, а атакующий в своем запросе намеренно указывает поддержку только RC4 (техника Downgrade), KDC может пойти навстречу и выдать ответ в уязвимом формате RC4 для обеспечения "обратной совместимости".

5. Как быстро злоумышленник может взломать хеш AS-REP?

Это зависит от типа шифрования и сложности пароля. Хеш RC4 взламывается на современных видеокартах (например, связка из нескольких RTX 4090) со скоростью миллиарды комбинаций в секунду. Простой пароль будет найден за секунды. Взлом AES-256 идёт на несколько порядков медленнее, однако если пароль словарный ("Spring2026!"), он всё равно будет скомпрометирован за минуты.

6. Поможет ли многофакторная аутентификация (MFA/2FA) защитить от AS-REP Roasting?

К сожалению, стандартная интеграция MFA для RDP, VPN или веб-сервисов не затрагивает низкоуровневые запросы протокола Kerberos к контроллеру домена. Если на учетной записи отключена Pre-Authentication, атакующий всё равно получит зашифрованный AS-REP и сможет восстановить пароль. Защита должна осуществляться на уровне архитектуры AD.

7. Существуют ли легитимные причины отключать Kerberos Pre-Authentication в 2026 году?

Практически нет. Все современные операционные системы и корпоративные приложения поддерживают стандартный процесс Kerberos с Pre-Auth (внедренный еще в Windows 2000). Единственное исключение — крайне специфические устаревшие устройства (legasy-принтеры, старые RADIUS-серверы), которые нельзя обновить. В таких случаях для них нужно создавать изолированные учетные записи со сгенерированным 64-символьным паролем.

8. Как выявить попытки эксплуатации задним числом (Threat Hunting), если SIEM не выдал алерт?

Специалисты Blue Team могут проанализировать архивы логов безопасности DC (Security.evtx), отфильтровав Event ID 4768. Необходимо выгрузить все события, где Pre-Authentication Type равно 0. Если эти запросы исходят от IP-адресов рабочих станций пользователей, а не от легитимных серверов инфраструктуры (или если объем таких запросов аномально высок), это явный повод для глубокого расследования инцидента (IR).